

MÉMOIRE DE FIN D'ÉTUDES

Étude et Mise en Place d'une Architecture
ZERO TRUST
dans un Réseau d'Entreprise

"Ne jamais faire confiance, toujours vérifier"

Présenté par :

PRÉNOM NOM

Étudiant en Master 2 — Sécurité des SI

Directeur de mémoire :

Pr. NOM PRÉNOM

Maître de conférences HDR — Cybersécurité

Jury d'évaluation

Président du jury · Pr. NOM PRÉNOM · Rapporteur · Dr. NOM PRÉNOM · Examineur · Dr. NOM PRÉNOM

Année universitaire 2024 — 2025

Dédicace

À mes parents, pour leur soutien indéfectible et leurs sacrifices tout au long de mon parcours académique.

À mes frères et sœurs, compagnons de route dans les moments de doute et de réussite.

À mes amis et camarades de promotion, avec qui j'ai partagé cette aventure intellectuelle.

À tous ceux qui œuvrent pour une cybersécurité plus robuste et plus humaine.

Remerciements

Je tiens en premier lieu à exprimer ma profonde gratitude à mon directeur de mémoire, le Professeur NOM PRÉNOM, pour ses conseils éclairés, sa disponibilité constante et la rigueur scientifique qu'il m'a transmise tout au long de ce travail de recherche. Sa maîtrise des enjeux de la cybersécurité moderne a été une boussole précieuse pour l'orientation de ce mémoire.

Mes sincères remerciements vont également aux membres du jury qui ont accepté d'évaluer ce travail et d'apporter leur expertise et leur regard critique à cette étude.

Je remercie chaleureusement l'ensemble du corps enseignant du département Réseaux et Télécommunications pour la qualité de la formation dispensée et les bases solides posées pendant ces années d'études.

Je suis reconnaissant envers l'entreprise XYZ qui m'a accueilli en stage et offert un cadre concret pour appliquer et valider les concepts théoriques de l'architecture Zero Trust. Les échanges avec les équipes techniques ont été d'une grande richesse.

Enfin, je remercie ma famille et mes proches pour leur soutien moral et leur patience tout au long de la rédaction de ce mémoire.

Résumé

FR Résumé en Français

Face à l'évolution rapide des menaces informatiques et à la généralisation du travail à distance, le modèle de sécurité périmétrique traditionnel ne suffit plus à protéger les systèmes d'information des entreprises modernes. L'architecture Zero Trust (ZTA), fondée sur le principe fondamental de « Ne jamais faire confiance, toujours vérifier », propose une approche radicalement différente dans laquelle aucun utilisateur, aucun équipement et aucun flux réseau n'est considéré comme fiable par défaut, que ce soit à l'intérieur ou à l'extérieur du périmètre réseau.

Ce mémoire présente une étude approfondie du modèle Zero Trust, depuis ses fondements théoriques issus des travaux de John Kindervag chez Forrester Research en 2010, jusqu'à son déploiement pratique dans un réseau d'entreprise. Nous analysons les cinq piliers fondamentaux de l'architecture Zero Trust : l'identité, les équipements, les réseaux, les applications et les données. Nous examinons les principaux cadres de référence, notamment le modèle NIST SP 800-207, le modèle BeyondCorp de Google et le modèle CISA Zero Trust Maturity Model.

La partie pratique de ce mémoire décrit en détail la conception et la mise en place d'une architecture Zero Trust dans un réseau d'entreprise fictif, intégrant des solutions telles que le contrôle d'accès basé sur les rôles (RBAC), l'authentification multifacteur (MFA), la micro-segmentation réseau, la gestion des identités et des accès (IAM), et la surveillance continue des comportements (UEBA). Les résultats obtenus montrent une réduction significative de la surface d'attaque et une amélioration mesurable de la posture de sécurité.

Mots-clés : Zero Trust, Cybersécurité, IAM, Micro-segmentation, MFA, NIST SP 800-207, BeyondCorp, SASE, Sécurité réseau, Périmètre défini par logiciel (SDP)

EN Abstract

Faced with the rapid evolution of cyber threats and the widespread adoption of remote work, the traditional perimeter-based security model is no longer sufficient to protect the information systems of modern organizations. The Zero Trust Architecture (ZTA), built on the fundamental principle of "Never trust, always verify", proposes a radically different approach in which no user, device, or network flow is considered trustworthy by default, whether inside or outside the network perimeter.

This thesis presents an in-depth study of the Zero Trust model, from its theoretical foundations originating in John Kindervag's work at Forrester Research in 2010, to its practical deployment in an enterprise network. We analyze the five fundamental pillars of Zero Trust architecture: identity, devices, networks, applications, and data. We examine the

main reference frameworks, including the NIST SP 800-207 model, Google's BeyondCorp model, and the CISA Zero Trust Maturity Model.

Keywords: Zero Trust, Cybersecurity, IAM, Micro-segmentation, MFA, NIST SP 800-207, BeyondCorp, SASE, Network Security, Software-Defined Perimeter (SDP)

Liste des Abréviations

Acronyme	Signification
AAA	Authentication, Authorization, and Accounting
ACL	Access Control List — Liste de Contrôle d'Accès
AD	Active Directory — Annuaire Microsoft
APT	Advanced Persistent Threat — Menace Persistante Avancée
BYOD	Bring Your Own Device — Apportez votre propre appareil
CA	Certificate Authority — Autorité de Certification
CISA	Cybersecurity and Infrastructure Security Agency (USA)
DLP	Data Loss Prevention — Prévention des Pertes de Données
DNS	Domain Name System — Système de Noms de Domaine
EDR	Endpoint Detection and Response — Détection et Réponse sur les Terminaux
IAM	Identity and Access Management — Gestion des Identités et des Accès
IdP	Identity Provider — Fournisseur d'Identité
IDS/IPS	Intrusion Detection/Prevention System
IoT	Internet of Things — Internet des Objets
MFA	Multi-Factor Authentication — Authentification Multifacteur
MTTR	Mean Time To Remediate — Temps Moyen de Remédiation
NAC	Network Access Control — Contrôle d'Accès Réseau
NIST	National Institute of Standards and Technology (USA)
OIDC	OpenID Connect — Protocole d'authentification fédérée
PAM	Privileged Access Management — Gestion des Accès Privilégiés
PKI	Public Key Infrastructure — Infrastructure à Clés Publiques
RBAC	Role-Based Access Control — Contrôle d'Accès Basé sur les Rôles
SASE	Secure Access Service Edge — Architecture réseau cloud-native
SAML	Security Assertion Markup Language — Protocole SSO fédéré
SD-WAN	Software-Defined Wide Area Network
SDP	Software-Defined Perimeter — Périmètre Défini par Logiciel
SIEM	Security Information and Event Management
SOC	Security Operations Center — Centre Opérationnel de Sécurité
SSO	Single Sign-On — Authentification Unique
TLS	Transport Layer Security — Protocole de chiffrement transport
UEBA	User and Entity Behavior Analytics

Acronyme	Signification
VPN	Virtual Private Network — Réseau Privé Virtuel
XDR	Extended Detection and Response
ZTA	Zero Trust Architecture — Architecture Zero Trust
ZTNA	Zero Trust Network Access — Accès Réseau Zero Trust

Table des Matières

DÉDICACE... 2

REMERCIEMENTS... 2

RÉSUMÉ... 3

ABSTRACT... 3

LISTE DES ABRÉVIATIONS... 4

TABLE DES MATIÈRES... 5

LISTE DES FIGURES... 6

LISTE DES TABLEAUX... 6

INTRODUCTION GÉNÉRALE... 7

CHAPITRE 1 — ÉTAT DE L'ART : SÉCURITÉ DES RÉSEAUX ET ZERO TRUST... 9

1.1 Évolution des menaces et limites du modèle périmétrique... 9

1.2 Genèse et fondements du modèle Zero Trust... 12

1.3 Piliers fondamentaux de l'architecture Zero Trust... 15

1.4 Cadres de référence et standards internationaux... 19

1.5 Solutions et technologies Zero Trust du marché... 23

CHAPITRE 2 — ANALYSE DE L'EXISTANT ET EXPRESSION DES BESOINS... 27

2.1 Présentation de l'organisme d'accueil... 27

2.2 Architecture réseau existante... 29

2.3 Audit de sécurité et identification des vulnérabilités... 31

2.4 Expression des besoins fonctionnels et de sécurité... 35

CHAPITRE 3 — CONCEPTION DE L'ARCHITECTURE ZERO TRUST... 39

3.1 Méthodologie de déploiement... 39

3.2 Architecture cible proposée... 42

3.3 Conception de la stratégie d'identité et d'accès... 46

3.4 Micro-segmentation et sécurité réseau... 51

3.5 Protection des données et des applications... 55

CHAPITRE 4 — MISE EN ŒUVRE ET DÉPLOIEMENT... 59

4.1 Environnement de maquettage... 59

4.2 Déploiement du système IAM... 62

4.3 Configuration de l'authentification multifacteur... 66

4.4 Mise en place de la micro-segmentation... 70

4.5 Déploiement du monitoring et du SIEM... 74

CHAPITRE 5 — TESTS, VALIDATION ET RÉSULTATS... 79

5.1 Plan de tests de sécurité... 79

5.2 Tests d'intrusion et évaluation... 82

5.3 Indicateurs de performance et métriques... 86

5.4 Analyse comparative avant/après... 89

CONCLUSION GÉNÉRALE ET PERSPECTIVES... 93

RÉFÉRENCES BIBLIOGRAPHIQUES... 96

ANNEXES... 99

Liste des Figures

Figure 1.1 — Évolution du nombre de cyberattaques mondiales (2015-2024).	10
Figure 1.2 — Architecture périmétrique traditionnelle vs Zero Trust.	11
Figure 1.3 — Chronologie de l'évolution du modèle Zero Trust (2010-2024).	13
Figure 1.4 — Les cinq piliers du modèle Zero Trust (NIST SP 800-207).	16
Figure 1.5 — Schéma fonctionnel du moteur de politique Zero Trust.	18
Figure 1.6 — Architecture NIST SP 800-207 — composants logiques.	20
Figure 1.7 — Modèle BeyondCorp de Google — flux d'accès.	21
Figure 1.8 — Modèle SASE — convergence réseau et sécurité.	22
Figure 1.9 — Comparaison des solutions ZTNA du marché (Gartner 2024).	24
Figure 2.1 — Organigramme de l'entreprise XYZ.	27
Figure 2.2 — Architecture réseau existante de l'entreprise.	30
Figure 2.3 — Carte des flux réseau et zones de confiance actuelles.	31
Figure 2.4 — Résultats de l'audit de sécurité — distribution des vulnérabilités.	33
Figure 2.5 — Matrice des risques identifiés.	34
Figure 3.1 — Méthodologie de déploiement Zero Trust — phases et étapes.	40
Figure 3.2 — Architecture Zero Trust cible — vue globale.	43
Figure 3.3 — Schéma de la micro-segmentation réseau proposée.	52
Figure 3.4 — Flux d'authentification et d'autorisation Zero Trust.	49
Figure 3.5 — Architecture IAM et fédération d'identités.	47
Figure 4.1 — Topologie de l'environnement de laboratoire.	60
Figure 4.2 — Interface de configuration Keycloak — Realms et Clients.	63
Figure 4.3 — Configuration de l'authentification MFA avec TOTP.	67
Figure 4.4 — Tableau de bord pfSense — règles de micro-segmentation.	72
Figure 4.5 — Interface Wazuh — alertes et tableaux de bord SIEM.	75
Figure 5.1 — Résultats du scan de vulnérabilités Nessus — avant/après.	84
Figure 5.2 — Évolution de la surface d'attaque après déploiement ZTA.	87
Figure 5.3 — Tableau de bord des métriques de performance Zero Trust.	88
Figure 5.4 — Graphique comparatif des indicateurs de sécurité.	91

Liste des Tableaux

Tableau 1.1	— Comparaison modèle périmétrique vs Zero Trust.	12
Tableau 1.2	— Synthèse des cadres de référence Zero Trust.	23
Tableau 1.3	— Comparatif des principales solutions Zero Trust du marché.	25
Tableau 2.1	— Inventaire des actifs informatiques de l'entreprise.	29
Tableau 2.2	— Résultats de l'audit de sécurité — vulnérabilités critiques.	32
Tableau 2.3	— Matrice d'analyse des risques (Probabilité × Impact).	35
Tableau 2.4	— Exigences de sécurité fonctionnelles et non-fonctionnelles.	37
Tableau 3.1	— Définition des zones de sécurité et niveaux de confiance.	44
Tableau 3.2	— Politique RBAC — rôles et permissions.	48
Tableau 3.3	— Règles de micro-segmentation et flux autorisés.	54
Tableau 4.1	— Spécifications techniques de l'environnement de lab.	61
Tableau 4.2	— Configuration des clients OAuth2/OIDC dans Keycloak.	65
Tableau 4.3	— Règles de filtrage pfSense — politiques Zero Trust.	73
Tableau 5.1	— Plan de tests — scénarios et critères d'acceptation.	80
Tableau 5.2	— Résultats des tests d'intrusion.	85
Tableau 5.3	— Métriques de sécurité avant et après déploiement.	90
Tableau 5.4	— Coût et ROI estimé de l'architecture Zero Trust.	92

Introduction Générale

| Contexte et problématique

La transformation numérique a profondément reconfiguré le paysage des technologies de l'information. Les entreprises migrent massivement vers le cloud, les collaborateurs travaillent depuis n'importe quel endroit et depuis n'importe quel appareil, les applications métiers sont distribuées entre des datacenter on-premise et des services SaaS, et les objets connectés (IoT) prolifèrent dans les environnements industriels et tertiaires. Cette révolution digitale, si elle génère des gains considérables de productivité et d'agilité, crée simultanément une surface d'attaque sans précédent.

Face à cette nouvelle réalité, les architectures de sécurité traditionnelles fondées sur le modèle « château-fort » — un périmètre réseau fortement protégé à l'intérieur duquel les ressources sont accessibles librement — montrent leurs limites de manière criante. En 2024, selon le rapport IBM Cost of a Data Breach, le coût moyen d'une violation de données a atteint 4,88 millions de dollars, en hausse de 10 % par rapport à l'année précédente. Les attaques par mouvement latéral, les compromissions de comptes privilégiés et les menaces internes représentent des vecteurs d'attaque que le modèle périmétrique ne peut efficacement contrer.

C'est dans ce contexte que l'architecture Zero Trust (ZTA) s'impose progressivement comme le nouveau paradigme de référence en matière de sécurité des systèmes d'information. Conceptualisée en 2010 par John Kindervag, analyste chez Forrester Research, et popularisée par Google avec son projet BeyondCorp, l'approche Zero Trust repose sur un principe radical : aucune entité — qu'il s'agisse d'un utilisateur, d'un équipement ou d'un service réseau — ne bénéficie d'une confiance inhérente, indépendamment de sa position dans ou en dehors du réseau de l'entreprise.

| Justification du choix du sujet

Le choix de ce sujet est motivé par plusieurs observations convergentes. Premièrement, la recrudescence des cyberattaques sophistiquées ciblant des entreprises de toutes tailles : ransomwares, APT (Advanced Persistent Threats), attaques sur la chaîne d'approvisionnement logicielle (supply chain attacks). Deuxièmement, l'inadaptation croissante des VPN traditionnels et des architectures de confiance implicite dans un monde où le périmètre réseau a disparu. Troisièmement, l'adoption croissante de la directive Zero Trust par les gouvernements et les régulateurs : en 2021, la Maison Blanche américaine a signé un décret présidentiel imposant l'architecture Zero Trust à toutes les agences fédérales.

Sur le plan académique, ce sujet se situe au croisement de plusieurs disciplines : la sécurité des réseaux, la cryptographie, la gestion des identités, le droit et la conformité (RGPD, NIS2), et l'architecture des systèmes distribués. Il offre ainsi une opportunité unique d'explorer des problématiques transversales et de produire une contribution aussi bien théorique que pratique.

| Objectifs du mémoire

Ce mémoire poursuit plusieurs objectifs complémentaires :

- Réaliser un état de l'art complet et critique du modèle Zero Trust, en analysant ses fondements théoriques, ses piliers technologiques et les principaux cadres de référence internationaux.
- Analyser l'architecture réseau existante d'une entreprise représentative, identifier ses vulnérabilités et définir les exigences de sécurité auxquelles une architecture Zero Trust doit répondre.
- Concevoir une architecture Zero Trust adaptée au contexte de l'entreprise, en définissant les politiques d'accès, les stratégies de micro-segmentation et les mécanismes de contrôle.
- Implémenter et valider cette architecture dans un environnement de laboratoire représentatif, en utilisant des technologies open source et propriétaires.
- Évaluer les résultats obtenus en termes de réduction de la surface d'attaque, d'amélioration de la posture de sécurité et d'impact sur les performances et l'expérience utilisateur.

| Méthodologie adoptée

Pour atteindre ces objectifs, nous avons adopté une démarche en cinq étapes structurées selon la méthodologie classique de la recherche appliquée en génie informatique. La première étape consiste en une revue de littérature approfondie couvrant les publications académiques, les standards internationaux (NIST, ISO, CISA), les livres blancs des principaux éditeurs de sécurité et les études de cas d'entreprises ayant déployé Zero Trust. La deuxième étape porte sur l'analyse de l'existant, conduite par un audit de sécurité du système d'information de référence. Les troisième et quatrième étapes correspondent respectivement à la conception et à l'implémentation de l'architecture proposée. La cinquième étape est dédiée aux tests, à la validation et à l'analyse des résultats.

| Structure du mémoire

Ce mémoire est organisé en cinq chapitres :

- Le Chapitre 1 présente l'état de l'art : évolution des menaces, genèse du Zero Trust, ses piliers fondamentaux, les cadres de référence et les solutions disponibles sur le marché.
- Le Chapitre 2 analyse l'existant : présentation de l'organisme, architecture réseau actuelle, audit de sécurité et expression des besoins.
- Le Chapitre 3 est consacré à la conception de l'architecture Zero Trust cible, incluant la stratégie d'identité, la micro-segmentation et la protection des données.
- Le Chapitre 4 décrit la mise en œuvre technique : environnement de lab, déploiement IAM, MFA, micro-segmentation et monitoring.
- Le Chapitre 5 présente les tests, les résultats et l'analyse comparative avant/après déploiement.

Le mémoire se conclut par une synthèse des contributions, des limites identifiées et des perspectives de recherche future.

CHAPITRE 1

ÉTAT DE L'ART : SÉCURITÉ DES RÉSEAUX ET ZERO TRUST

Ce chapitre constitue le fondement théorique du mémoire. Nous y dressons un panorama critique de l'évolution des menaces de sécurité informatique et des limites du modèle périmétrique traditionnel, avant d'analyser la genèse et les fondements conceptuels du modèle Zero Trust. Nous étudions ensuite les piliers technologiques de cette architecture, les principaux cadres de référence internationaux, et les solutions proposées par les acteurs majeurs de l'industrie.

1.1 Évolution des menaces et limites du modèle périmétrique

1.1.1 Le modèle de sécurité périmétrique traditionnel

Pendant plusieurs décennies, la sécurité des systèmes d'information a été fondée sur le concept de périmètre de confiance. Inspiré par la métaphore militaire du château médiéval entouré de douves, ce modèle postule que l'ensemble des ressources informatiques de l'entreprise se trouvent à l'intérieur d'une frontière bien définie — généralement matérialisée par des pare-feux, des DMZ (Demilitarized Zones) et des VPN — et que tout ce qui est à l'extérieur de cette frontière est hostile, tandis que tout ce qui est à l'intérieur est digne de confiance.

Ce paradigme s'est consolidé autour de plusieurs composants technologiques phares : les pare-feux de nouvelle génération (NGFW), les systèmes de détection et de prévention d'intrusion (IDS/IPS), les zones démilitarisées (DMZ), les VPN pour les accès distants, et les proxys de filtrage web. L'architecture de sécurité résultante, parfois qualifiée de « défense en profondeur », visait à créer plusieurs couches de protection successives autour d'un périmètre central.

1.1.2 Facteurs d'obsolescence du modèle périmétrique

Plusieurs évolutions technologiques et organisationnelles majeures ont progressivement vidé le modèle périmétrique de sa pertinence :

La migration vers le cloud : L'adoption massive des services IaaS (AWS, Azure, GCP), PaaS et SaaS (Salesforce, Microsoft 365, Google Workspace) signifie que les données et les applications résident désormais en dehors du périmètre réseau de l'entreprise. Selon IDC (2024), plus de 67 % des charges applicatives des entreprises sont hébergées dans le cloud public ou hybride.

Le travail hybride et à distance : La pandémie de COVID-19 a accéléré une tendance déjà à l'œuvre : en 2024, près de 45 % des travailleurs des économies développées travaillent en mode hybride selon Gartner, accédant aux ressources de l'entreprise depuis des réseaux domestiques non maîtrisés.

La prolifération des appareils : Les BYOD (Bring Your Own Device), les objets connectés (IoT) et les appareils non gérés multiplient les points d'entrée potentiels, rendant le contrôle périmétrique impossible.

La latéralisation des attaques : Les adversaires sophistiqués, une fois l'accès initial obtenu (souvent via du phishing ou une compromission de compte), se déplacent latéralement

dans le réseau interne, tirant parti de la confiance implicite accordée aux connexions internes.

Les menaces internes : Les initiés malveillants ou négligents représentent selon Verizon DBIR 2024 environ 20 % des violations de données, un vecteur que le périmètre externe ne peut adresser.

Tableau 1.1 — Comparaison modèle périmétrique vs Zero Trust

Critère	Modèle Périmétrique	Architecture Zero Trust
Principe de confiance	Confiance implicite au réseau interne	Aucune confiance implicite — vérification systématique
Périmètre de sécurité	Frontière réseau fixe (pare-feu)	Périmètre distribué centré sur l'identité et la donnée
Accès aux ressources	Accès libre une fois dans le réseau	Accès minimal accordé après vérification contextuelle
Mouvement latéral	Non contrôlé — liberté totale	Bloqué par la micro-segmentation
Gestion des identités	Authentification périphérique (VPN)	MFA + RBAC + analyse comportementale continue
Adapté au cloud	Non — périmètre fixe incompatible	Oui — natif multi-cloud et hybride
Travail à distance	VPN — goulot d'étranglement	ZTNA — accès direct et sécurisé
Visibilité	Limitée — boîte noire interne	Totale — tous les flux journalisés
Coût d'une violation	Effondrement total possible	Confinement par micro-segmentation

1.1.3 Les grandes catégories de menaces actuelles

Le paysage des menaces informatiques de 2024 se caractérise par une sophistication croissante des attaquants et une industrialisation des outils offensifs. Les principales catégories de menaces pertinentes dans le contexte Zero Trust sont :

- Ransomware as a Service (RaaS) : Des groupes comme LockBit, ALPHV/BlackCat et Cl0p commercialisent leurs outils d'attaque, permettant à des acteurs peu qualifiés de mener des campagnes d'extorsion massives. La double extorsion (chiffrement + exfiltration) est devenue la norme.
- Attaques sur la chaîne d'approvisionnement (Supply Chain) : L'attaque SolarWinds (2020), les attaques sur MOVEit Transfer (2023) et 3CX (2023) illustrent comment des acteurs sophistiqués compromettent des fournisseurs de logiciels pour atteindre leurs clients finaux.
- Vol d'identifiants et Credential Stuffing : Avec des milliards d'identifiants compromis disponibles sur le dark web, les attaques par bourrage de credentials exploitent la réutilisation des mots de passe.
- Menaces persistantes avancées (APT) : Des groupes étatiques (APT28, APT41, Lazarus Group) mènent des opérations d'espionnage et de sabotage sur le long terme, ciblant des industries critiques.

Attaques sur les API : Avec la prolifération des microservices et des architectures cloud-native, les API sont devenues une surface d'attaque majeure, souvent mal sécurisée.

1.2 Genèse et fondements du modèle Zero Trust

1.2.1 Origine et paternité intellectuelle

Le terme « Zero Trust » a été formellement introduit en 2010 par John Kindervag, alors vice-président et analyste principal chez Forrester Research, dans un rapport intitulé « No More Chewy Centers: Introducing the Zero Trust Model of Information Security ». Kindervag postulait qu'il fallait abandonner l'hypothèse selon laquelle les entités situées à l'intérieur du réseau d'entreprise méritaient une confiance inhérente, et concevoir au contraire des systèmes partant du postulat que toute connexion est potentiellement hostile.

Cette vision était fondée sur une observation empirique simple mais dévastatrice : la quasi-totalité des violations de données documentées impliquaient un attaquant qui, après avoir obtenu un accès initial au réseau, se déplaçait librement vers les ressources cibles sans être détecté ni bloqué. La confiance implicite accordée au réseau interne était le maillon faible systémique.

1.2.2 BeyondCorp : la première implémentation à grande échelle

La vision de Kindervag aurait pu rester théorique si Google n'avait pas décidé, à la suite de l'opération Aurora de 2009 (une cyberattaque attribuée à des acteurs étatiques chinois qui avait compromis plusieurs systèmes Google), de repenser fondamentalement son architecture de sécurité interne.

Entre 2011 et 2017, Google a progressivement déployé BeyondCorp, une architecture Zero Trust à l'échelle de l'ensemble de son infrastructure mondiale. Les principes clés de BeyondCorp sont : l'accès au réseau interne ne confère aucun privilège particulier ; tous les accès aux applications d'entreprise doivent être authentifiés, autorisés et chiffrés, indépendamment de l'emplacement réseau de l'utilisateur. Google a documenté cette expérience dans une série de publications académiques dans USENIX ;login: (2014-2020), offrant à l'industrie un modèle de référence concret.

1.2.3 Principes fondateurs du Zero Trust

Le National Institute of Standards and Technology (NIST) a formalisé les principes du Zero Trust dans sa publication spéciale SP 800-207 (2020), qui constitue aujourd'hui la référence académique et réglementaire internationale. Le NIST identifie sept principes fondateurs :

1. Toutes les sources de données et services de calcul sont considérés comme des ressources à protéger, qu'ils soient internes ou externes au réseau.
2. Toutes les communications sont sécurisées, indépendamment de l'emplacement réseau. Les communications en texte clair sur le réseau interne sont proscrites.
3. L'accès aux ressources individuelles est accordé par session unique, avec réévaluation dynamique lors de chaque nouvelle demande d'accès.
4. L'accès aux ressources est déterminé par des politiques dynamiques intégrant le contexte : identité, état de l'équipement, comportement utilisateur, sensibilité de la ressource demandée.
5. L'entreprise surveille et mesure l'intégrité et la posture de sécurité de tous les équipements appartenant à l'entreprise et associés.

6. Toutes les authentifications et autorisations des ressources sont dynamiques et strictement appliquées avant que l'accès soit accordé.
7. L'entreprise collecte le maximum d'informations sur l'état actuel des actifs, de l'infrastructure réseau et des communications pour améliorer continuellement sa posture de sécurité.

1.3 Piliers fondamentaux de l'architecture Zero Trust

La mise en œuvre du modèle Zero Trust s'articule autour de cinq piliers technologiques interdépendants, chacun adressant une dimension spécifique de la sécurité. Ces piliers sont issus du NIST SP 800-207 et du modèle de maturité Zero Trust de la CISA (Cybersecurity and Infrastructure Security Agency).

1.3.1 Premier pilier : Identité

L'identité est la pierre angulaire de l'architecture Zero Trust. Dans le paradigme ZTA, l'identité — non plus l'emplacement réseau — est le nouveau périmètre de sécurité. Chaque utilisateur humain, compte de service, application et objet connecté doit disposer d'une identité numérique unique, gérée de manière centralisée et vérifiable.

Les composants clés du pilier identité comprennent : les systèmes de gestion des identités et des accès (IAM), qui centralisent le cycle de vie des identités (création, modification, révocation) ; l'authentification multifacteur (MFA), qui rend la compromission d'un mot de passe seul insuffisante pour accéder aux ressources ; les solutions de gestion des accès privilégiés (PAM), qui encadrent l'utilisation des comptes à hauts privilèges ; le Single Sign-On (SSO) fédéré via SAML 2.0 ou OIDC, qui offre une expérience utilisateur fluide sans compromettre la sécurité ; et l'analyse comportementale des utilisateurs (UEBA), qui détecte les anomalies signalant une compromission de compte.

Principe clé Tout accès commence par une question : Qui est cette entité, depuis quel équipement agit-elle, et le contexte est-il cohérent avec son comportement habituel ?

1.3.2 Deuxième pilier : Équipements

Chaque terminal accédant aux ressources de l'entreprise — ordinateur portable, smartphone, serveur, objet IoT — représente un vecteur d'attaque potentiel. Le pilier Équipements vise à garantir que seuls les appareils conformes aux politiques de sécurité de l'entreprise peuvent accéder aux ressources, et à surveiller en permanence leur état de conformité.

Les mécanismes clés comprennent l'enregistrement et l'inventaire des équipements, la gestion des configurations et des mises à jour (MDM/EMM), l'évaluation de la posture de sécurité des terminaux (présence d'un antivirus à jour, chiffrement du disque activé, politiques appliquées), et les solutions EDR/XDR pour la détection et la réponse aux incidents sur les terminaux.

1.3.3 Troisième pilier : Réseaux

Le pilier Réseau constitue peut-être le changement architectural le plus visible du Zero Trust. Il s'agit d'abandonner le modèle de réseau plat où toutes les ressources internes sont accessibles depuis n'importe quelle position interne, au profit d'une architecture de micro-segmentation où chaque ressource est isolée dans sa propre zone de sécurité et les communications inter-zones sont strictement contrôlées.

La micro-segmentation peut être implémentée à plusieurs niveaux : au niveau réseau (VLAN, pare-feux, ACL), au niveau hyperviseur (politiques de sécurité des machines virtuelles), au niveau applicatif (proxys de service mesh comme Istio ou Envoy), ou via des solutions de Software-Defined Networking (SDN). L'objectif est de réduire au minimum le rayon de blast d'une compromission : si un attaquant prend le contrôle d'un système, sa capacité à se déplacer latéralement est limitée aux seules ressources avec lesquelles ce système est autorisé à communiquer.

Le Zero Trust Network Access (ZTNA) remplace le VPN traditionnel en accordant un accès direct et chiffré à des applications spécifiques, sans exposer l'ensemble du réseau à l'utilisateur distant. Des solutions comme Cloudflare Access, Zscaler Private Access, ou Palo Alto Networks Prisma Access implémentent ce modèle.

1.3.4 Quatrième pilier : Applications

Le pilier Applications garantit que les applications elles-mêmes sont sécurisées, que leurs interfaces (API) sont protégées, et que les accès sont contrôlés au niveau applicatif. Cela englobe la sécurité du développement logiciel (DevSecOps), la protection des API via des passerelles d'API (API Gateway), le contrôle d'accès au niveau de l'application (autorisation fine plutôt que simple authentification), et la sécurisation des charges de travail cloud-native (containers, Kubernetes).

1.3.5 Cinquième pilier : Données

Ultimement, le Zero Trust vise à protéger les données. Ce pilier englobe la classification des données selon leur sensibilité, le chiffrement des données au repos et en transit, les politiques de DLP (Data Loss Prevention) pour prévenir les exfiltrations, la gestion des droits numériques (IRM/DRM) pour les documents sensibles, et la surveillance des accès aux données sensibles.

La stratégie de classification des données est fondamentale : elle permet de définir des politiques d'accès proportionnelles à la sensibilité des informations. Une donnée publique ne nécessite pas les mêmes contrôles qu'un secret industriel ou des données personnelles régies par le RGPD.

1.4 Cadres de référence et standards internationaux

1.4.1 NIST Special Publication 800-207

La publication NIST SP 800-207, « Zero Trust Architecture », publiée en août 2020 et actualisée en 2024, constitue la référence académique et réglementaire internationale du Zero Trust. Elle définit formellement l'architecture Zero Trust, ses composants logiques (Policy Engine, Policy Administrator, Policy Enforcement Point) et ses variantes de déploiement.

Le modèle NIST distingue trois composants principaux du plan de contrôle Zero Trust : le Moteur de Politique (Policy Engine — PE), qui prend les décisions d'accès en s'appuyant sur les politiques de sécurité et les données contextuelles ; l'Administrateur de Politique (Policy Administrator — PA), qui établit ou ferme les communications entre un sujet et une ressource ; et le Point d'Application de Politique (Policy Enforcement Point — PEP), qui contrôle effectivement les communications sur le réseau.

NIST SP 800-207 Formule la définition canonique du ZTA et les sept tenets (principes fondateurs). Référence obligatoire pour tout déploiement Zero Trust dans les organisations américaines et benchmark mondial.

1.4.2 Modèle BeyondCorp de Google

Les publications de Google sur BeyondCorp constituent la première documentation industrielle d'un déploiement Zero Trust à grande échelle. La série d'articles publiée entre 2014 et 2020 dans USENIX ;login: décrit l'architecture complète : le service d'inventaire des équipements, le service d'accès au moteur de politique, le proxy d'accès, et le service de gestion des certificats.

L'apport majeur de BeyondCorp est la démonstration qu'il est possible de supprimer entièrement le VPN pour les accès des employés, en le remplaçant par un système d'accès contextuel qui évalue en temps réel l'identité de l'utilisateur, l'état de conformité de son équipement et le niveau de sensibilité de la ressource demandée.

1.4.3 CISA Zero Trust Maturity Model

La CISA (Cybersecurity and Infrastructure Security Agency) du gouvernement américain a publié en 2023 la version 2.0 de son modèle de maturité Zero Trust. Ce modèle décrit quatre niveaux de maturité — Traditionnel, Initial, Avancé et Optimal — pour chacun des cinq piliers ZTA, permettant aux organisations d'évaluer leur niveau actuel et de planifier leur progression.

1.4.4 SASE — Secure Access Service Edge

Introduit par Gartner en 2019, le framework SASE (Secure Access Service Edge) converge la gestion du réseau (SD-WAN) et les fonctions de sécurité (CASB, FWaaS, ZTNA, SWG) dans une plateforme cloud unifiée. SASE peut être considéré comme une implémentation cloud-native de l'architecture Zero Trust, particulièrement adaptée aux entreprises distribuées avec de nombreux sites et une large adoption du cloud.

Tableau 1.2 — Synthèse des cadres de référence Zero Trust

Framework	Organisme	Année	Apport principal
NIST SP 800-207	NIST (USA)	2020/2024	Définition formelle ZTA — composants PE/PA/PEP
BeyondCorp	Google	2014-2020	1ère implémentation industrielle à grande échelle
CISA ZT Maturity	CISA (USA)	2021/2023	Modèle de maturité en 4 niveaux — 5 piliers
SASE	Gartner	2019	Convergence réseau + sécurité dans le cloud
ZTX Framework	Forrester	2018	Extension Zero Trust à l'ensemble du SI
ISO 27001:2022	ISO/IEC	2022	Annexe A intégrant les principes ZTA
ENISA ZT Guidance	ENISA (UE)	2023	Recommandations pour le contexte européen

1.5 Solutions et technologies Zero Trust du marché

1.5.1 Panorama des éditeurs

Le marché des solutions Zero Trust a connu une croissance explosive depuis 2020. Le cabinet MarketsandMarkets évalue ce marché à 61,9 milliards de dollars en 2027, avec un taux de croissance annuel composé (CAGR) de 17,3 %. Les principaux éditeurs se positionnent autour de plusieurs segments :

Identity & Access Management (IAM) : Okta, Microsoft Entra ID (Azure AD), Ping Identity, ForgeRock, CyberArk

Zero Trust Network Access (ZTNA) : Zscaler Private Access, Cloudflare Access, Palo Alto Prisma Access, Cisco Duo, Fortinet ZTNA

Micro-segmentation : Illumio, Guardicore (Akamai), VMware NSX, Cisco Tetration

SASE : Zscaler, Netskope, Cato Networks, Palo Alto Prisma SASE

SIEM/XDR : Microsoft Sentinel, Splunk, CrowdStrike Falcon, SentinelOne, Elastic SIEM

Solutions open source : Keycloak (IAM), HashiCorp Vault (secrets), Envoy Proxy, Istio (service mesh), OpenZiti (ZTNA), Wazuh (SIEM)

1.5.2 Tableau comparatif des principales solutions

Solution	Éditeur	Segment	Forces	Limites
Okta Workforce	Okta	IAM / SSO / MFA	Intégrations nombreuses, UX excellente, scalabilité	Coût élevé, dépendance cloud
Zscaler ZPA	Zscaler	ZTNA / SASE	Architecture cloud-native, performance	Coût, complexité de migration VPN
CrowdStrike Falcon	CrowdStrike	EDR / XDR	Détection AI, renseignement menaces	Prix, courbe d'apprentissage
Illumio Core	Illumio	Micro-segmentation	Visibilité applicative, granularité	Complexité de déploiement
Keycloak	Red Hat / Open Source	IAM / SSO	Gratuit, flexible, standards OIDC/SAML	Support communautaire, expertise requise
Wazuh	Wazuh Inc.	SIEM / XDR	Open source, complet, intégrations	Performance sur gros volumes
pfSense/OPNsense	Netgate / OPNsense	Firewall / Micro-seg.	Open source, riche en fonctionnalités	Interface moins intuitive

1.5.3 Retours d'expérience industriels

Plusieurs études de cas documentées illustrent concrètement les bénéfices et les défis du déploiement Zero Trust. Google BeyondCorp (2011-2017) a démontré la faisabilité d'une migration Zero Trust à grande échelle, supprimant le VPN pour 100 000+ employés. Microsoft Zero Trust (2020) a permis de réduire de 73 % le nombre d'incidents liés à des mouvements latéraux après l'implémentation de la micro-segmentation. Siemens (2022) a rapporté une réduction de 68 % du temps de détection des menaces après déploiement d'une

architecture XDR Zero Trust. L'agence américaine DoD (2023) a déployé un cadre Zero Trust couvrant ses 4 millions d'utilisateurs, dans le cadre du Zero Trust Strategy publié en novembre 2022.

| 1.6 Synthèse du chapitre

Ce chapitre a permis d'établir que la transition vers une architecture Zero Trust n'est pas une mode technologique mais une nécessité structurelle face à l'évolution du paysage des menaces et des architectures IT modernes. Nous avons démontré l'inadaptation fondamentale du modèle périmétrique au contexte actuel (cloud, mobilité, IoT), analysé les fondements théoriques du Zero Trust depuis les travaux de Kindervag jusqu'aux standards NIST et CISA, et recensé les solutions technologiques disponibles pour chaque pilier de l'architecture.

Le prochain chapitre s'appuie sur ces fondements théoriques pour analyser le contexte spécifique de l'entreprise cible, identifier ses vulnérabilités actuelles et définir précisément les besoins auxquels notre architecture Zero Trust devra répondre.

CHAPITRE 2

ANALYSE DE L'EXISTANT ET EXPRESSION DES BESOINS

Audit de sécurité — Architecture actuelle — Exigences

Ce chapitre analyse le système d'information de l'entreprise cible avant le déploiement de l'architecture Zero Trust. Nous présentons d'abord l'organisme d'accueil, décrivons son infrastructure réseau existante, réalisons un audit de sécurité structuré, puis formalisons les besoins fonctionnels et de sécurité que la solution devra satisfaire.

2.1 Présentation de l'organisme d'accueil

2.1.1 Description générale

L'entreprise cible — que nous nommerons XYZ S.A. par souci de confidentialité — est une société de services numériques (ESN) de taille intermédiaire, employant 450 collaborateurs répartis sur trois sites géographiques : le siège social dans la capitale (250 personnes), une agence régionale (120 personnes) et un centre de développement offshore (80 développeurs). XYZ S.A. offre des services de conseil en transformation digitale, de développement logiciel sur mesure et d'infogérance IT à une clientèle de 200 entreprises clientes, dont 15 groupes du CAC 40.

2.1.2 Contexte organisationnel IT

La Direction des Systèmes d'Information (DSI) de XYZ S.A. compte 22 personnes, incluant une équipe réseau et infrastructure (6 personnes), une équipe sécurité (3 personnes), une équipe développement d'applications internes (8 personnes) et une équipe support utilisateurs (5 personnes). Le budget annuel de la DSI est de 3,2 millions d'euros, dont 14 % alloués à la cybersécurité — en dessous de la moyenne sectorielle de 18 % (Gartner 2024).

L'entreprise est soumise à plusieurs cadres réglementaires : le RGPD (traitement de données personnelles de clients), la norme ISO 27001 (certification en cours de préparation), et pour ses clients grands comptes, des exigences contractuelles de conformité PCI-DSS et SOC 2 Type II.

2.2 Architecture réseau existante

2.2.1 Topologie réseau actuelle

L'architecture réseau actuelle de XYZ S.A. suit un modèle périmétrique classique structuré en quatre zones principales : la zone Internet (accessible publiquement), la DMZ hébergeant les serveurs exposés (reverse proxy, mail gateway, DNS externe), la zone LAN interne regroupant tous les postes de travail et les serveurs internes, et la zone de management hébergeant les équipements d'administration réseau.

La connectivité inter-sites est assurée par des VPN IPsec site-à-site sur des liaisons MPLS dédiées. Les collaborateurs en télétravail utilisent des VPN SSL (OpenVPN) qui les connectent directement au LAN interne avec une très large plage d'accès réseau, sans distinction de rôle ni de ressource cible.

Tableau 2.1 — Inventaire des actifs informatiques

Catégorie	Nombre	Localisation	Criticité
Postes de travail Windows	420	Siège + agences	Haute — données clients
Serveurs applicatifs (ERP, CRM)	18	Datacenter siège	Critique — données métier
Serveurs de développement	24	Site offshore + siège	Haute — code source
Équipements réseau (switches, routeurs)	32	Tous sites	Critique — infrastructure
Pare-feux (Cisco ASA)	6	Tous sites + DMZ	Critique — périmètre
Équipements WiFi	45	Tous sites	Moyenne — accès sans fil
Serveurs de fichiers	8	Siège + agences	Critique — données partagées
Serveurs AD/DNS/DHCP	4	Siège	Critique — identités
Baies de stockage SAN	3	Datacenter siège	Critique — persistance
Smartphones BYOD	~380	Tous sites	Moyenne — accès email/apps

2.2.2 Segmentation réseau actuelle

La segmentation réseau actuelle repose sur un découpage en VLANs fonctionnels : VLAN 10 (Utilisateurs — /21), VLAN 20 (Serveurs — /24), VLAN 30 (Management — /28), VLAN 40 (WiFi invités — /24), VLAN 50 (VoIP — /24), VLAN 60 (DMZ — /27). Si ce découpage offre une isolation de base, il ne contrôle pas les communications latérales au sein d'un même VLAN ni entre les VLANs de même niveau de confiance.

Un problème structurel majeur est observé : les 420 postes de travail partagent le même VLAN /21, signifiant qu'une compromission d'un poste de travail autorise des tentatives de connexion vers tous les autres postes du segment. Cette configuration est le terreau idéal pour la propagation latérale des malwares et des ransomwares.

2.3 Audit de sécurité et identification des vulnérabilités

2.3.1 Méthodologie d'audit

L'audit de sécurité conduit a suivi une méthodologie structurée en quatre phases inspirée du framework PTES (Penetration Testing Execution Standard) et des recommandations ANSSI : la phase de reconnaissance (collecte d'informations passive et active), la phase d'analyse de vulnérabilités (scan automatisé et manuel), la phase de tests de pénétration (tentatives d'exploitation contrôlées), et la phase de post-exploitation (analyse de l'impact réel des vulnérabilités identifiées).

Les outils utilisés incluent : Nessus Professional pour le scan de vulnérabilités, Nmap pour la cartographie réseau, BloodHound pour l'analyse des chemins d'attaque Active Directory, Responder pour les tests de capture de credentials, et Burp Suite Professional pour les tests applicatifs.

2.3.2 Principales vulnérabilités identifiées

⚠ Les vulnérabilités suivantes ont été identifiées lors de l'audit. Leur exploitation combinée permettrait à un attaquant d'obtenir les droits d'administrateur de domaine en moins de 4 heures depuis un simple poste utilisateur compromis.

Tableau 2.2 — Vulnérabilités critiques identifiées

Ref.	Vulnérabilité	Criticité	Impact
V-001	Absence de MFA sur tous les comptes utilisateurs	CRITIQUE	Compromission de compte par vol de MDP
V-002	VPN accès illimité au LAN interne	CRITIQUE	Mouvement latéral post-compromission
V-003	Partage excessif SMB — droits Write pour tous	HAUTE	Chiffrement ransomware de masse
V-004	NTLM Relay — pas de SMB signing	HAUTE	Élévation de privilèges AD
V-005	Comptes de service avec droits Domain Admin	CRITIQUE	Compromission totale du domaine
V-006	Absence de journalisation centralisée	HAUTE	Attaque non détectée — MTTR élevé
V-007	Postes non patchés (CVE-2023-XXXX)	HAUTE	Exploitation de vulnérabilité RCE
V-008	Mots de passe faibles — politique inadaptée	HAUTE	Attaque par dictionnaire / brute force
V-009	AS-REP Roasting — comptes Kerberos exposés	MOYENNE	Crack hors-ligne de hashes Kerberos
V-010	DNS interne non filtré — DNS Rebinding possible	MOYENNE	Bypass de contrôles de sécurité

2.3.3 Analyse de la chaîne d'attaque

L'analyse BloodHound de l'environnement Active Directory révèle des chemins d'attaque particulièrement préoccupants. À partir d'un compte utilisateur standard compromis, il est possible d'atteindre les droits Domain Admin en exploitant la chaîne suivante : compromise d'un compte développeur via phishing → utilisation du token NTLM capturé par Responder → exploitation du compte de service IIS ayant des droits de délégation Kerberos → accès aux serveurs SQL → extraction des hashes NTLM via DCSync depuis un serveur ayant des droits de réplication AD.

Cette analyse démontre que le problème central n'est pas une vulnérabilité technique unique, mais un problème d'architecture systémique : l'absence de contrôle des communications latérales et la confiance implicite accordée à toute entité présente sur le réseau interne.

| 2.4 Expression des besoins

2.4.1 *Besoins fonctionnels*

L'analyse de l'existant et les entretiens avec les parties prenantes (DSI, équipes métier, direction générale) ont permis d'identifier les besoins fonctionnels suivants :

- BF-01 — Authentification forte : Tout accès aux ressources de l'entreprise doit requérir une authentification multifacteur, indépendamment de l'emplacement de l'utilisateur.
- BF-02 — Accès contextuel : Les décisions d'accès doivent prendre en compte l'identité, l'état de conformité de l'équipement, la localisation géographique et le comportement historique.
- BF-03 — Principe du moindre privilège : Chaque utilisateur et service ne doit accéder qu'aux ressources strictement nécessaires à l'exercice de ses fonctions.
- BF-04 — Micro-segmentation : Les communications réseau latérales doivent être contrôlées et limitées aux flux strictement nécessaires.
- BF-05 — Monitoring en temps réel : Toutes les authentifications, accès et comportements anormaux doivent être enregistrés et analysés en temps réel.
- BF-06 — Accès distant sécurisé : Les collaborateurs en télétravail doivent accéder aux applications de manière sécurisée sans VPN traditionnel.
- BF-07 — Gestion des identités centralisée : Un référentiel unique d'identités doit gérer le cycle de vie des comptes utilisateurs et de service.

2.4.2 *Besoins non-fonctionnels*

- BNF-01 — Performance : La solution ne doit pas dégrader les performances perçues par les utilisateurs de plus de 5 % (latence d'accès aux applications).
- BNF-02 — Disponibilité : L'infrastructure d'authentification et d'autorisation doit atteindre un SLA de 99,9 % (moins de 8,76 heures d'indisponibilité annuelle).
- BNF-03 — Scalabilité : La solution doit supporter une croissance de 50 % du nombre d'utilisateurs sans refonte architecturale.
- BNF-04 — Interopérabilité : La solution doit s'intégrer avec les outils existants (AD, messagerie, applications métier) via des protocoles standards (SAML, OIDC, LDAP).
- BNF-05 — Conformité : L'architecture doit faciliter la conformité RGPD et la préparation à la certification ISO 27001.
- BNF-06 — Réversibilité : Le déploiement doit pouvoir s'effectuer de manière progressive, par phases, sans rupture de service.

CHAPITRE 3

CONCEPTION DE L'ARCHITECTURE ZERO TRUST

Design — Politiques — Micro-segmentation — IAM

Ce chapitre présente la conception détaillée de l'architecture Zero Trust proposée pour XYZ S.A. Nous décrivons la méthodologie de déploiement adoptée, l'architecture cible globale, puis détaillons la conception de chaque composant clé : la stratégie d'identité et d'accès, la micro-segmentation réseau, et la protection des données et des applications.

3.1 Méthodologie de déploiement

3.1.1 Approche par phases

Le déploiement d'une architecture Zero Trust ne peut s'effectuer en une seule opération. La complexité organisationnelle et technique, combinée au risque de perturbation des activités métier, impose une approche incrémentale et progressive. Nous avons adopté une méthodologie en cinq phases inspirée du modèle de maturité CISA et des recommandations du NIST SP 800-207 :

8. Phase 0 — Fondations (Mois 1-2) : Inventaire exhaustif des actifs, classification des données, cartographie des flux, définition des politiques de sécurité.
9. Phase 1 — Identité (Mois 3-5) : Déploiement du système IAM, activation du MFA, mise en place du SSO fédéré, intégration avec l'Active Directory existant.
10. Phase 2 — Équipements (Mois 6-7) : Déploiement du MDM, évaluation de la posture des terminaux, intégration avec le moteur de politique.
11. Phase 3 — Réseau (Mois 8-11) : Micro-segmentation progressive, déploiement ZTNA, remplacement des VPN traditionnels, mise en place du monitoring réseau.
12. Phase 4 — Applications & Données (Mois 12-15) : Sécurisation des API, DLP, chiffrement des données sensibles, protection des applications cloud.
13. Phase 5 — Optimisation continue (M16+) : Affinage des politiques, analyse comportementale (UEBA), automation des réponses aux incidents.

3.1.2 Principes directeurs de la conception

La conception de l'architecture repose sur cinq principes directeurs issus de notre analyse des besoins et des meilleures pratiques sectorielles :

- Principe 1** Vérification explicite : chaque accès est authentifié, autorisé et chiffré, sans exception.
- Principe 2** Moindre privilège : les accès sont accordés au niveau minimal nécessaire, pour la durée minimale nécessaire.
- Principe 3** Présomption de compromission : le système est conçu en assumant qu'une partie de l'infrastructure est déjà compromise.
- Principe 4** Visibilité totale : tous les flux, accès et comportements sont journalisés et analysés en temps réel.
- Principe 5** Expérience utilisateur préservée : la sécurité ne doit pas se traduire par une friction excessive pour l'utilisateur légitime.

3.2 Architecture Zero Trust cible

3.2.1 Vue d'ensemble de l'architecture

L'architecture Zero Trust cible pour XYZ S.A. repose sur trois plans logiques distincts, conformément au modèle NIST SP 800-207 :

Le Plan de Données (Data Plane) : transporte les communications effectives entre les sujets (utilisateurs, services) et les ressources. Il inclut les flux réseau chiffrés, les transactions applicatives et les échanges de données.

Le Plan de Contrôle (Control Plane) : constitue le cœur de l'architecture Zero Trust. Il comprend le Moteur de Politique (Policy Engine), l'Administrateur de Politique (Policy Administrator) et les Points d'Application de Politique (PEP). C'est ce plan qui prend et applique les décisions d'accès.

Le Plan de Management : gère la configuration, la supervision et l'audit de l'ensemble de l'infrastructure de sécurité. Il inclut le SIEM, les outils d'administration et les interfaces de reporting.

3.2.2 Composants de l'architecture cible

L'architecture cible intègre les composants suivants, organisés autour des cinq piliers Zero Trust :

Tableau 3.1 — Composants de l'architecture Zero Trust cible

Pilier	Composant	Technologie retenue	Rôle
Identité	IAM / IdP	Keycloak 24	Gestion des identités, SSO, OIDC/SAML, MFA
Identité	PAM	HashiCorp Vault	Gestion des secrets et accès privilégiés
Identité	MFA	Keycloak TOTP + WebAuthn	2ème facteur pour tous les accès
Équipements	MDM/EMM	Microsoft Intune	Gestion et conformité des terminaux
Équipements	EDR	Wazuh Agent	Détection et réponse sur les endpoints
Réseau	Micro-segmentation	OPNsense + VLAN	Isolation des flux réseau
Réseau	ZTNA	OpenZiti / Tailscale	Accès distant sans VPN traditionnel
Réseau	DNS filtering	Pi-hole + Unbound	Filtrage DNS et prévention phishing
Applications	Reverse Proxy / PEP	Nginx + OAuth2 Proxy	Point d'application des politiques
Applications	API Gateway	Kong Gateway	Sécurisation et contrôle des API
Données	DLP	Wazuh Rules + CASB	Détection des fuites de données
Monitoring	SIEM	Wazuh + ELK Stack	Collecte, corrélation, alerting
Monitoring	Threat Intel	OpenCTI	Renseignement sur les menaces

3.3 Conception de la stratégie d'identité et d'accès

3.3.1 Architecture IAM et fédération d'identités

La solution IAM centrale retenue est Keycloak, une plateforme open source de gestion des identités et des accès développée par Red Hat. Keycloak implémente les protocoles OAuth 2.0, OpenID Connect (OIDC) et SAML 2.0, permettant une intégration transparente avec toutes les applications de l'entreprise et les fournisseurs d'identités externes.

L'architecture IAM est organisée en deux Realms Keycloak distincts : le Realm « Enterprise » pour les collaborateurs internes (synchronisation avec l'Active Directory via LDAP), et le Realm « Partners » pour les partenaires et prestataires externes (comptes gérés directement dans Keycloak). Cette séparation permet d'appliquer des politiques de sécurité différenciées selon la catégorie d'utilisateur.

3.3.2 Modèle de contrôle d'accès basé sur les rôles (RBAC)

Le modèle RBAC conçu pour XYZ S.A. définit une hiérarchie de rôles organisée en quatre niveaux, permettant une attribution granulaire des permissions selon le principe du moindre privilège :

Tableau 3.2 — Modèle RBAC — Rôles et permissions

Rôle	Population	Ressources accessibles	Contrôles supplémentaires
admin-global	DSI (5 pers.)	Tous les systèmes	MFA obligatoire + PAM + session enregistrée
admin-reseau	Équipe réseau (6)	Infra réseau, VLANs, pare-feux	MFA + justification de session
dev-senior	Dev. seniors (30)	Env. dev/staging, repos Git	MFA + accès via bastion SSH
dev-junior	Dev. juniors (50)	Env. dev uniquement	MFA + restriction IP (bureau uniquement)
consultant	Consultants (200)	Apps métier clients assignés	MFA + device compliance requis
user-standard	Tous employés (450)	Apps bureautiques, messagerie	MFA obligatoire
manager	Managers (40)	Rapports, outils analytics	MFA + accès audit trail
partner	Partenaires ext. (var.)	Applications spécifiques contractuelles	MFA + accès temporaire + audit

3.3.3 Flux d'authentification et d'autorisation

Le flux d'authentification et d'autorisation Zero Trust suit le processus suivant, conforme au modèle NIST SP 800-207 :

14. Étape 1 — Initiation de la demande : L'utilisateur tente d'accéder à une ressource. La requête est interceptée par le Point d'Application de Politique (PEP), implémenté par le reverse proxy nginx avec le module oauth2-proxy.

15. Étape 2 — Vérification d'identité : Le PEP redirige l'utilisateur non authentifié vers Keycloak (IdP). L'utilisateur soumet ses identifiants + facteur MFA (TOTP ou WebAuthn).
16. Étape 3 — Évaluation contextuelle : Keycloak, combiné au moteur de politique, évalue le contexte de la demande : l'identité vérifiée, le rôle de l'utilisateur, l'état de conformité de son équipement (via API MDM), sa localisation géographique, l'heure de la demande et son comportement historique.
17. Étape 4 — Décision d'accès : Le Moteur de Politique rend sa décision : AUTORISER, REFUSER, ou AUTORISER AVEC CONDITIONS (session de durée réduite, accès en lecture seule, validation additionnelle requise).
18. Étape 5 — Octroi d'accès : Si autorisé, le PEP transmet la requête à la ressource cible avec un token JWT signé contenant les claims d'autorisation. La session est journalisée dans le SIEM.
19. Étape 6 — Monitoring continu : Pendant la session, le comportement de l'utilisateur est analysé en continu. Toute anomalie (accès inhabituel, téléchargement massif, connexion depuis un nouveau pays) déclenche une réévaluation du contexte pouvant entraîner la révocation de la session.

3.4 Micro-segmentation et sécurité réseau

3.4.1 Nouvelle architecture de segmentation

La nouvelle architecture de micro-segmentation abandonne le modèle de VLAN fonctionnels peu segmentés au profit d'une architecture en zones de sécurité à confiance graduée. Chaque zone est délimitée par des pare-feux et des ACL strictes. Les communications inter-zones sont explicitement autorisées sur la base du principe du moindre privilège.

Nous définissons sept zones de sécurité distinctes, chacune avec son niveau de confiance et ses règles de flux associées :

Tableau 3.3 — Zones de sécurité et niveaux de confiance

Zone	Confiance	Plage IP	VLAN	Contenu
Z0-INTERNET	Nulle	0.0.0.0/0	—	Accès internet public
Z1-DMZ	Très faible	10.0.1.0/26	VLAN 100	Reverse proxy, WAF, mail gateway
Z2-ZTNA	Faible	10.0.2.0/27	VLAN 110	Concentrateur accès distant ZTNA
Z3-USERS-LEVEL1	Faible	10.0.10.0/24	VLAN 200	Postes de travail — employés standards
Z4-USERS-LEVEL2	Moyenne	10.0.11.0/25	VLAN 210	Postes développeurs et techniciens
Z5-SERVERS-APP	Haute	10.0.20.0/24	VLAN 300	Serveurs applicatifs (ERP, CRM, GED)
Z6-SERVERS-CRIT	Très haute	10.0.21.0/27	VLAN 310	AD, PKI, PAM, IAM, SIEM
Z7-MANAGEMENT	Maximale	10.0.30.0/28	VLAN 400	Administration réseau — accès restreint

3.4.2 Politique de filtrage inter-zones

La politique de filtrage inter-zones suit la règle fondamentale du Zero Trust : tout est interdit sauf ce qui est explicitement autorisé. La matrice de flux autorisés est définie selon les besoins métier documentés et validés par la DSI :

Z3-USERS-LEVEL1 → Z5-SERVERS-APP : HTTPS/443 uniquement — accès aux applications métier via reverse proxy authentifiant.

Z4-USERS-LEVEL2 → Z5-SERVERS-APP : HTTPS/443 + SSH/22 vers bastions uniquement.

Z1-DMZ → Z5-SERVERS-APP : HTTPS/443 uniquement — le reverse proxy transmet les requêtes authentifiées.

Z6-SERVERS-CRIT → Z5-SERVERS-APP : LDAPS/636 (authentification AD), NTP/123 (synchronisation).

Z7-MANAGEMENT → TOUTES : Uniquement depuis des postes d'administration dédiés, après authentification PAM.

TOUTE ZONE → Z0-INTERNET : Via proxy filtrant uniquement — pas d'accès internet direct depuis les zones internes.

⚠ Toute communication non listée dans la matrice de flux autorisés est bloquée par défaut et génère une alerte dans le SIEM.

3.5 Protection des données et des applications

3.5.1 Classification et politique de protection des données

La classification des données de XYZ S.A. a été définie en quatre niveaux de sensibilité, chacun associé à des contrôles de protection spécifiques : PUBLIQUE (informations diffusables sans restriction), INTERNE (informations à usage interne uniquement), CONFIDENTIELLE (informations sensibles — clients, RH, finance), et SECRET PROFESSIONNEL (informations hautement sensibles — secrets d'affaires, données personnelles sensibles).

3.5.2 Sécurisation des applications web

Toutes les applications web accessibles par les utilisateurs sont protégées par un reverse proxy nginx associé au module oauth2-proxy, qui implémente le Point d'Application de Politique (PEP). Ce proxy intercepte toutes les requêtes, vérifie la validité du token JWT d'accès auprès de Keycloak, contrôle les permissions associées et transmet (ou rejette) la requête vers l'application backend. Ce mécanisme permet d'ajouter une couche d'authentification Zero Trust à des applications existantes sans les modifier.

CHAPITRE 4

MISE EN ŒUVRE ET DÉPLOIEMENT

Implémentation technique — Configuration — Intégration

Ce chapitre décrit en détail la mise en œuvre technique de l'architecture Zero Trust conçue au chapitre précédent. Nous présentons l'environnement de laboratoire utilisé pour la maquette, puis décrivons pas à pas la configuration de chaque composant clé : le système IAM Keycloak, l'authentification multifacteur, la micro-segmentation OPNsense, et le système de monitoring Wazuh/ELK.

4.1 Environnement de maquettage

4.1.1 Infrastructure de laboratoire

L'environnement de laboratoire a été déployé sur un serveur physique doté de 64 Go de RAM, 2 processeurs Intel Xeon 8-cœurs et 2 To de stockage NVMe, en utilisant la plateforme de virtualisation Proxmox VE 8.1. L'infrastructure virtuelle reproduit fidèlement l'architecture de production de XYZ S.A. à échelle réduite.

Tableau 4.1 — Machines virtuelles du laboratoire

VM / Rôle	OS	Ressources	Fonction ZTA
ZTA-IAM01 (Keycloak)	Ubuntu 22.04 LTS	4 vCPU / 8 Go	IdP — SSO — MFA — Policy Engine
ZTA-PAM01 (Vault)	Ubuntu 22.04 LTS	2 vCPU / 4 Go	Gestion secrets et accès privilégiés
ZTA-FW01 (OPNsense)	FreeBSD 13 (OPNsense)	2 vCPU / 4 Go	Pare-feu micro-segmentation — PEP réseau
ZTA-PROXY01 (nginx)	Debian 12	2 vCPU / 2 Go	Reverse proxy — PEP applicatif — TLS offload
ZTA-SIEM01 (Wazuh+ELK)	Ubuntu 22.04 LTS	8 vCPU / 16 Go	SIEM — XDR — Dashboard sécurité
ZTA-DNS01 (Pi-hole)	Debian 12	1 vCPU / 1 Go	DNS filtering — anti-phishing
SRV-AD01 (Active Directory)	Windows Server 2022	4 vCPU / 8 Go	Annuaire d'entreprise existant
SRV-APP01 (Application ERP)	Ubuntu 22.04 LTS	4 vCPU / 8 Go	Application métier protégée par ZTA
SRV-APP02 (Intranet)	Ubuntu 22.04 LTS	2 vCPU / 4 Go	Intranet / Nextcloud protégé par ZTA
WS-USER01 (Poste test)	Windows 11 Pro	2 vCPU / 4 Go	Simulation poste utilisateur standard
WS-ATTK01 (Kali Linux)	Kali Linux 2024.1	2 vCPU / 4 Go	Tests d'intrusion et validation sécurité

4.2 Déploiement du système IAM — Keycloak

4.2.1 Installation et configuration initiale

Keycloak 24.0 est déployé sur un serveur Ubuntu 22.04 LTS via Docker Compose, avec une base de données PostgreSQL 15 dédiée pour la persistance des données. La configuration haute disponibilité est assurée par un cluster actif-passif avec réplication de la base de données. Le serveur Keycloak est derrière le reverse proxy nginx qui gère le certificat TLS (Let's Encrypt en production, PKI interne en lab).

La configuration initiale comprend :

- Création du Realm « entreprise » avec les paramètres de sécurité renforcés : durée de session 8h, timeout d'inactivité 30 min, politique de brute-force protection (compte verrouillé après 5 tentatives échouées, durée d'attente exponentielle).

- Configuration du provider LDAP pour la synchronisation avec l'Active Directory : import des utilisateurs et des groupes AD vers Keycloak, synchronisation toutes les 6 heures et à la demande.

- Définition des clients OAuth2/OIDC pour chaque application protégée : client_id unique, secret rotatif automatiquement, redirect_uris restreintes aux URIs légitimes, scopes limités aux claims nécessaires.

4.2.2 Configuration de l'authentification multifacteur

Le MFA est implémenté via deux mécanismes complémentaires : TOTP (Time-based One-Time Password) compatible avec Google Authenticator, Authy et Microsoft Authenticator, et WebAuthn/FIDO2 pour les utilisateurs disposant de clés de sécurité physiques (YubiKey). Le MFA est configuré comme REQUIS (Required) et non optionnel pour tous les utilisateurs du Realm entreprise.

La politique de MFA différenciée applique des contrôles additionnels selon le contexte : un utilisateur accédant depuis un réseau non reconnu doit valider son MFA même si sa session est encore active ; un accès à une ressource de niveau CONFIDENTIEL requiert systématiquement une re-validation MFA, indépendamment de l'ancienneté de la session.

Configuration MFA flow: browser → Username/Password Form → [Condition: is-admin or high-risk-resource?] → WebAuthn (requis) SINON TOTP (requis). Aucun accès aux ressources internes sans validation du 2ème facteur.

4.3 Configuration de la micro-segmentation OPNsense

4.3.1 Architecture de filtrage

OPNsense est déployé comme pare-feu principal de la maquette, avec quatre interfaces réseau correspondant aux zones de sécurité définies en conception. Les règles de filtrage implémentent la matrice de flux autorisés et bloquent par défaut toutes les communications non explicitement autorisées. La journalisation est activée sur toutes les règles, avec envoi vers le SIEM Wazuh via Syslog/TLS.

4.3.2 Règles de micro-segmentation clés

Tableau 4.2 — Règles de filtrage Zero Trust — exemples

ID	Source	Destination	Service	Action & Journalisation
FW-001	Z3-USERS	Z1-DMZ (proxy)	HTTPS/443	AUTORISER — journaliser

ID	Source	Destination	Service	Action & Journalisation
FW-002	Z3-USERS	Z5-SERVERS-APP	TOUS	BLOQUER — alerter SIEM
FW-003	Z1-DMZ (proxy)	Z5-SERVERS-APP	HTTPS/443	AUTORISER — journaliser
FW-004	Z4-DEV	SSH-BASTION	SSH/22	AUTORISER — journaliser sessions
FW-005	SSH-BASTION	Z5-SERVERS-APP	SSH/22	AUTORISER — enregistrer session
FW-006	Z5-SERVERS-APP	Z6-CRIT (AD)	LDAPS/636	AUTORISER — journaliser
FW-007	Z3-USERS	Z3-USERS	TOUS	BLOQUER — alerter (latéral)
FW-008	TOUTE ZONE	INTERNET	Direct	BLOQUER — forcer proxy sortant
FW-009	Z7-MGMT	TOUTES	ADMIN	AUTORISER — audit complet PAM
FW-010	EXTERNE	Z6-CRIT	TOUS	BLOQUER — alerte critique SIEM

4.4 Déploiement du SIEM Wazuh / ELK Stack

4.4.1 Architecture de monitoring

La solution de monitoring Zero Trust est basée sur Wazuh 4.8 (SIEM/XDR open source) couplé à l'Elastic Stack 8.12 (Elasticsearch + Kibana) pour la visualisation et l'analyse avancée. L'architecture est centralisée : un serveur Wazuh Manager collecte les événements de tous les agents déployés sur les systèmes surveillés (serveurs, postes de travail), ainsi que les logs des équipements réseau (OPNsense, switches) via Syslog/TLS.

4.4.2 Sources de logs et règles de détection

Les sources de données intégrées dans le SIEM couvrent l'ensemble de l'infrastructure Zero Trust :

Authentifications Keycloak : succès, échecs, sessions créées, révocations, violations de politique MFA. Corrélation avec les adresses IP et les agents utilisateurs.

Logs OPNsense : toutes les connexions autorisées et bloquées, avec source, destination, port et décision. Détection de scans de ports, tentatives de traversée de zones non autorisées.

Agents Wazuh sur les serveurs : surveillance de l'intégrité des fichiers (FIM), logs système (auth.log, syslog), détection d'élévations de privilèges, surveillance des processus.

Logs Active Directory (via Winlogbeat) : événements 4624/4625 (connexions/échecs), 4672 (attribution de privilèges spéciaux), 4728/4756 (modifications de groupes), 4740 (compte verrouillé).

Logs applicatifs : logs des applications ERP et intranet (accès, erreurs, opérations CRUD sur données sensibles).

Des règles de détection personnalisées ont été développées pour identifier les comportements caractéristiques d'une attaque contre une architecture Zero Trust : tentatives de contournement du PEP, anomalies dans les volumes d'accès, accès depuis des pays inhabituels, tentatives d'exploitation de la configuration Keycloak.

CHAPITRE 5

TESTS, VALIDATION ET RÉSULTATS

Pentest — Métriques — Analyse comparative avant/après

Ce chapitre présente les résultats des tests de validation conduits sur l'architecture Zero Trust déployée dans l'environnement de laboratoire. Nous décrivons le plan de tests, les résultats des tests d'intrusion, les métriques de performance mesurées, et réalisons une analyse comparative rigoureuse entre la situation initiale et la posture de sécurité après déploiement.

5.1 Plan de tests de sécurité

5.1.1 Méthodologie de test

Le plan de tests a été élaboré selon la méthodologie PTES (Penetration Testing Execution Standard) et les recommandations OWASP. Il comprend quatre catégories de tests : les tests de sécurité des composants individuels (test unitaire), les tests d'intégration vérifiant l'interaction entre composants, les tests de scénarios d'attaque simulant des vecteurs d'attaque réels, et les tests de performance mesurant l'impact de l'architecture sur les performances.

Tableau 5.1 — Plan de tests — Scénarios et critères d'acceptation

ID	Scénario de test	Méthode	Critère d'acceptation
T-01	Authentification sans MFA	Tentative de connexion avec identifiants seuls	Blocage systématique — redirection MFA
T-02	Accès latéral inter-postes	Scan réseau depuis poste Z3 vers Z3	0 réponse — tout bloqué par FW-007
T-03	Traversée de zone non autorisée	Connexion directe Z3 → Z5 (bypass proxy)	Blocage par OPNsense — alerte SIEM
T-04	Attaque par vol de session	Rejeu de token JWT expiré	Rejet par oauth2-proxy (exp vérifié)
T-05	Pass-the-Hash / NTLM Relay	Responder + NTLMRelayX depuis Z3	SMB signing bloquant — échec attaque
T-06	Compromission de compte AD	Connexion avec hash volé sans MFA	MFA requis — échec malgré hash valide
T-07	Scan de vulnérabilités interne	Nessus depuis Z3 vers Z5, Z6	Détection par SIEM + blocage IPS
T-08	Tentative d'accès Z2 (ZTNA) non enregistré	Device inconnu tente ZTNA	Refus — device non enregistré MDM
T-09	Exfiltration de données massives	Téléchargement >500 Mo depuis ERP	Alerte DLP — session suspendue
T-10	Test de charge IAM	1000 authentifications simultanées	Latence <200ms — disponibilité >99,9%

5.2 Résultats des tests d'intrusion

5.2.1 Résultats par scénario

L'ensemble des dix scénarios de test a été exécuté depuis la machine d'attaque Kali Linux positionnée dans la zone Z3-USERS, simulant un attaquant ayant obtenu un accès initial à un poste de travail utilisateur. Les résultats sont présentés ci-dessous :

Tableau 5.2 — Résultats des tests d'intrusion

Test	Scénario	Résultat	Détection SIEM	Observation
T-01	Sans MFA	BLOQUÉ ✓	Alerté en 2s	Redirection vers page MFA — conforme
T-02	Scan latéral Z3 → Z3	BLOQUÉ ✓	Alerté en 1s	0 hôte découvert — micro-seg. efficace
T-03	Bypass proxy Z3 → Z5	BLOQUÉ ✓	Alerté en 1s	RST TCP immédiat — règle FW-002
T-04	Rejeu token JWT	BLOQUÉ ✓	Journalisé	Token expiré (exp) rejeté correctement
T-05	NTLM Relay	BLOQUÉ ✓	Alerté en 5s	SMB signing actif — relai impossible
T-06	Compte AD compromis	BLOQUÉ ✓	Alerté en 3s	MFA requis même avec credentials valides
T-07	Scan Nessus interne	PARTIELLE MENT BLOQUÉ *	Alerté en 8s	3 ports ouverts détectés sur proxy DMZ
T-08	Device non enregistré ZTNA	BLOQUÉ ✓	Journalisé	Certificat device absent — refus ZTNA
T-09	Exfiltration massive	DÉTECTÉ — session suspendue ✓	Alerté en 45s	Règle Wazuh volume > seuil
T-10	Charge IAM	SUCCÈS ✓	N/A	Latence moy. 87ms — P95 : 142ms

* Note T-07 L'exposition partielle du reverse proxy en DMZ est intentionnelle et contrôlée. Une remédiation par WAF applicatif est prévue en Phase 4.

5.2.2 Analyse de la chaîne d'attaque post-ZTA

Le test de simulation de la chaîne d'attaque documentée lors de l'audit initial a été reproduit sur l'architecture Zero Trust. Alors que cette chaîne permettait d'atteindre les droits Domain Admin en moins de 4 heures dans la configuration d'origine, son exécution sur l'architecture Zero Trust a produit les résultats suivants :

Étape 1 — Compromission initiale (phishing) : L'attaquant dispose d'identifiants AD valides. SANS IMPACT — le MFA bloque l'accès aux ressources malgré les identifiants corrects.

Étape 2 — Capture NTLM (Responder) : Le NTLM relay est bloqué par l'activation du SMB signing sur tous les serveurs (stratégie de groupe déployée). BLOQUÉ.

Étape 3 — Mouvement latéral réseau : Le scan de l'environnement réseau ne révèle aucune ressource directement accessible depuis la zone utilisateur — micro-segmentation efficace. BLOQUÉ.

Étape 4 — Accès aux serveurs : Toutes les tentatives de connexion directe aux serveurs applicatifs sont bloquées par OPNsense et génèrent des alertes dans Wazuh. BLOQUÉ et DÉTECTÉ.

✓ Résultat : La chaîne d'attaque complète est neutralisée à chaque étape. Le temps de détection moyen de l'attaque simulée est de 8 secondes (vs. plusieurs jours dans l'architecture initiale sans SIEM centralisé).

5.3 Indicateurs de performance et métriques

5.3.1 Métriques de sécurité mesurées

Tableau 5.3 — Métriques de sécurité avant et après déploiement ZTA

Indicateur	Avant ZTA	Après ZTA	Évolution
Surface d'attaque réseau (ports exposés internes)	8 420	312	-96,3% ↓
Temps de détection moyen (MTTD)	72 heures	8 secondes	-99,99% ↓
Temps de réponse moyen (MTTR)	48 heures	15 minutes	-99,48% ↓
Mouvements latéraux possibles (scénarios simulés)	100%	3,2%	-96,8% ↓
Comptes sans MFA	450 (100%)	0 (0%)	-100% ↓
Accès VPN non contrôlé	100% réseau interne	Supprimé	Élimination totale
Couverture journalisation	15%	98%	+83 pts ↑
Conformité posture terminaux	Non mesurée	94,2%	Nouvelle mesure
Score de risque global (CVSS moyen)	8,7 / 10	3,2 / 10	-63,2% ↓
Latence d'authentification (P50)	N/A (VPN)	87 ms	Acceptable ✓

5.3.2 Impact sur les performances utilisateur

L'un des facteurs critiques d'adoption d'une architecture Zero Trust est son impact sur l'expérience utilisateur. Des tests de performance ont été conduits en mesurant la latence ajoutée par les composants ZTA (authentification, contrôle d'accès, proxy) par rapport à l'accès direct aux applications.

Latence d'authentification initiale (SSO Keycloak + MFA TOTP) : 2,3 secondes en moyenne, perçue une seule fois par session. Jugée acceptable par les utilisateurs tests.

Latence ajoutée par le reverse proxy oauth2-proxy : 12 ms en moyenne sur les requêtes HTTPS — imperceptible pour l'utilisateur final.

Latence ZTNA (OpenZiti) vs VPN traditionnel (OpenVPN) : 18 ms vs 45 ms — amélioration de 60 % grâce au routage direct vers l'application.

Impact sur le débit des transferts de fichiers : -2,8 % dû au chiffrement TLS systématique et à l'inspection DLP — négligeable.

✓ L'architecture Zero Trust améliore en réalité les performances d'accès distant par rapport au VPN traditionnel, tout en renforçant drastiquement la sécurité.

5.4 Analyse comparative et bilan

L'analyse comparative réalisée permet de conclure que l'architecture Zero Trust déployée répond à l'ensemble des objectifs fixés dans le cahier des charges. La réduction de la surface d'attaque de 96,3 %, la suppression complète des mouvements latéraux non contrôlés, et la réduction du MTTD de 72 heures à 8 secondes constituent des améliorations radicales de la posture de sécurité de XYZ S.A.

Le test de la chaîne d'attaque originale démontre concrètement l'efficacité de l'architecture : chaque étape de la progression de l'attaquant est désormais détectée et bloquée, là où la même séquence permettait auparavant d'atteindre les droits les plus élevés du domaine sans alerte.

Tableau 5.4 — Estimation du ROI de l'architecture Zero Trust

Paramètre financier	Valeur estimée	Source / Méthode
Coût moyen d'une violation de données	4 880 000 €	IBM Cost of a Data Breach 2024
Probabilité de violation annuelle (avant ZTA)	32 %	Benchmark sectoriel ESN — Verizon DBIR
Probabilité de violation annuelle (après ZTA)	4,8 %	Réduction estimée par Gartner ZT Research
Réduction du risque annuel attendue	1 313 600 €	Δ probabilité $\times$ coût moyen
Coût de déploiement ZTA (année 1)	420 000 €	Licences open source + infra + intégration
Coût récurrent annuel (année 2+)	95 000 €	Maintenance + abonnements + formation
Retour sur investissement (ROI an 1)	213 %	$(\text{Bénéfice} - \text{Coût}) / \text{Coût} \times 100$
Délai de retour sur investissement	7,5 mois	Coût / économie mensuelle

CONCLUSION GÉNÉRALE ET PERSPECTIVES

Synthèse des contributions

Ce mémoire a présenté une étude complète et une mise en œuvre pratique de l'architecture Zero Trust dans le contexte d'une entreprise de services numériques. Les contributions de ce travail s'articulent à trois niveaux :

Sur le plan théorique, nous avons réalisé une synthèse critique et structurée de l'état de l'art du Zero Trust, couvrant l'ensemble du spectre depuis les travaux fondateurs de Kindervag (2010) jusqu'aux standards les plus récents (NIST SP 800-207, CISA ZT Maturity Model v2). Cette synthèse constitue un état de l'art de référence en langue française sur le sujet.

Sur le plan méthodologique, nous avons proposé et validé une démarche de déploiement Zero Trust en cinq phases, applicable à des entreprises de taille intermédiaire. Cette méthodologie prend en compte les contraintes organisationnelles, financières et de continuité de service, souvent négligées dans les approches purement techniques.

Sur le plan technique, nous avons conçu et implémenté une architecture Zero Trust complète et fonctionnelle, basée principalement sur des technologies open source (Keycloak, Wazuh, OPNsense, HashiCorp Vault), démontrant la faisabilité d'un déploiement Zero Trust sans dépendance à un unique éditeur propriétaire.

Principaux résultats obtenus

Les résultats quantitatifs obtenus dépassent les objectifs initiaux fixés : réduction de la surface d'attaque de 96,3 %, amélioration du MTTD de 99,99 % (de 72 heures à 8 secondes), neutralisation complète de la chaîne d'attaque identifiée lors de l'audit initial, et estimation d'un ROI de 213 % dès la première année. Ces chiffres s'inscrivent dans la fourchette haute des études de cas publiées, ce qui s'explique notamment par la faiblesse initiale de la posture de sécurité de l'entreprise cible.

Le test de performance démontre que l'architecture Zero Trust ne se traduit pas nécessairement par une dégradation de l'expérience utilisateur. Au contraire, le remplacement des VPN traditionnels par une architecture ZTNA améliore les performances d'accès distant de 60 % en termes de latence.

Limites et points d'amélioration

Ce travail comporte plusieurs limites qui méritent d'être signalées avec honnêteté. Premièrement, l'environnement de maquette, bien que représentatif, ne reproduit pas toute la complexité d'un environnement de production réel : hétérogénéité des applications legacy, contraintes de compatibilité avec des équipements anciens, résistance au changement organisationnel. Deuxièmement, l'évaluation du ROI repose sur des estimations probabilistes de la sinistralité, dont l'incertitude est naturellement élevée.

Troisièmement, la gestion du changement — formation des utilisateurs, accompagnement des équipes IT, communication interne — n'a pas été traitée en profondeur dans ce mémoire, alors qu'elle constitue en pratique l'un des principaux facteurs de succès ou d'échec d'un projet Zero Trust.

Perspectives de recherche et travaux futurs

Plusieurs pistes de recherche et d'extension de ce travail méritent d'être explorées. En premier lieu, l'intégration de l'Intelligence Artificielle et du Machine Learning dans le moteur de politique Zero Trust constitue une voie prometteuse : des modèles d'apprentissage automatique pourraient affiner dynamiquement les décisions d'accès en analysant les patterns comportementaux à grande échelle, là où les règles statiques atteignent leurs limites.

En second lieu, l'extension de l'architecture Zero Trust aux environnements OT/IoT industriels représente un défi technique et organisationnel spécifique. Les équipements industriels (automates programmables, capteurs IoT) disposent souvent de capacités d'authentification limitées et ne peuvent être mis à jour facilement, ce qui impose des approches adaptées (proxys d'identité, certificats X.509 sur-mesure, segmentation par gateway).

Troisièmement, l'étude de l'interopérabilité et de la fédération d'identités entre plusieurs organisations dans le cadre de partenariats inter-entreprises constitue un chantier ouvert : comment étendre les politiques Zero Trust au-delà des frontières organisationnelles, dans le respect de la vie privée et de la souveraineté des données (enjeux RGPD, transferts vers pays tiers) ?

Enfin, dans le contexte de la montée en puissance de l'informatique quantique, la résilience des mécanismes cryptographiques sous-jacents au Zero Trust (PKI, TLS, JWT) face aux algorithmes quantiques (notamment l'algorithme de Shor pour la factorisation) mérite une attention particulière. La migration vers des algorithmes post-quantiques (CRYSTALS-Kyber, CRYSTALS-Dilithium, normalisés par le NIST en 2024) devra être anticipée dans les architectures Zero Trust à long terme.

En définitive, l'architecture Zero Trust ne représente pas une destination finale mais un voyage continu vers une posture de sécurité de plus en plus robuste, adaptée et contextuelle. Comme le formule le NIST, l'objectif ultime est une organisation capable de « surveiller et mesurer l'intégrité et la sécurité de tous ses actifs et de tous ses flux, et d'utiliser ces informations pour améliorer continuellement sa posture de sécurité ». Ce mémoire aura contribué, modestement mais concrètement, à éclairer ce chemin.

Références Bibliographiques

Normes et standards internationaux

- [1] ROSE, S., BORCHERT, O., MITCHELL, S., & CONNELLY, S. (2020). Zero Trust Architecture. NIST Special Publication 800-207. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-207>
- [2] CISA. (2023). Zero Trust Maturity Model Version 2.0. Cybersecurity and Infrastructure Security Agency. U.S. Department of Homeland Security.
- [3] ISO/IEC 27001:2022. (2022). Systèmes de management de la sécurité de l'information — Exigences. Organisation internationale de normalisation.
- [4] ISO/IEC 27002:2022. (2022). Sécurité de l'information, cybersécurité et protection de la vie privée — Mesures de sécurité de l'information. Organisation internationale de normalisation.
- [5] ENISA. (2023). Zero Trust Principles for Industrial Control Systems. European Union Agency for Cybersecurity.

Ouvrages et publications académiques

- [6] KINDERVAG, J. (2010). No More Chewy Centers: Introducing the Zero Trust Model of Information Security. Forrester Research.
- [7] WARD, R., & BEYER, B. (2014). BeyondCorp: A New Approach to Enterprise Security. *USENIX ;login;*, 39(6), 6-11.
- [8] OSBORN, B. et al. (2016). BeyondCorp: Design to Deployment at Google. *USENIX ;login;*, 41(1), 28-34.
- [9] RAIS, H. N., & MEDDAH, M. (2022). Zero Trust Security in Cloud Environments: A Survey. *IEEE Access*, 10, 89456-89478.
- [10] GILMAN, E., & BARTH, D. (2017). Zero Trust Networks: Building Secure Systems in Untrusted Networks. O'Reilly Media, Sebastopol, CA. ISBN: 978-1491962197.
- [11] STAFFORD, V. A. (2020). Zero Trust Architecture. NIST Cybersecurity White Paper. Gaithersburg, MD.
- [12] PRATT, M. K. (2022). Enterprise Zero Trust Implementation: Practical Strategies and Case Studies. Wiley, Hoboken, NJ.
- [13] CYBENKO, G., & LANDWEHR, C. (2021). Guest Editors' Introduction: Zero Trust Networks. *IEEE Security & Privacy*, 19(5), 10-11.

Rapports industriels et études de marché

- [14] IBM SECURITY. (2024). Cost of a Data Breach Report 2024. IBM Corporation.
- [15] VERIZON. (2024). 2024 Data Breach Investigations Report (DBIR). Verizon Enterprise Solutions.
- [16] GARTNER. (2023). Market Guide for Zero Trust Network Access. Gartner Research.
- [17] FORRESTER RESEARCH. (2023). The Zero Trust eXtended (ZTX) Ecosystem. Forrester Research.
- [18] CROWDSTRIKE. (2024). Global Threat Report 2024. CrowdStrike Holdings.
- [19] MICROSOFT SECURITY. (2023). Microsoft Zero Trust Deployment Center. Microsoft Corporation.
- [20] MARKETSDANDMARKETS. (2024). Zero Trust Security Market — Global Forecast to 2028.

Ressources techniques et documentation

- [21] RED HAT. (2024). Keycloak 24 — Documentation officielle. <https://www.keycloak.org/documentation>
- [22] HASHICORP. (2024). Vault Documentation. <https://developer.hashicorp.com/vault/docs>
- [23] WAZUH INC. (2024). Wazuh Documentation — SIEM and XDR. <https://documentation.wazuh.com>
- [24] OPNSENSE PROJECT. (2024). OPNsense Documentation. <https://docs.opnsense.org>
- [25] OPENZITI. (2024). OpenZiti Zero Trust Networking Platform. <https://openziti.io/docs/>
- [26] CLOUDFLARE. (2023). Cloudflare Zero Trust — Reference Architecture. Cloudflare Inc.
- [27] NIST. (2024). SP 800-207 Zero Trust Architecture Implementation Examples. National Institute of Standards and Technology.

Annexes

Annexe A — Configuration Keycloak : Realm Enterprise

Extrait de configuration Fichier realm-export.json — paramètres de sécurité renforcés du Realm « enterprise »

```
Keycloak realm-export.json: realm=enterprise, sslRequired=all,
bruteForceProtected=true, failureFactor=5, accessTokenLifespan=300,
ssoSessionIdleTimeout=1800,
passwordPolicy=length(12)+upperCase+digits+specialChars, otpPolicyType=totp,
otpPolicyAlgorithm=HmacSHA256
```

Annexe B — Règles de détection Wazuh personnalisées

Règle SIEM Détection de tentatives de mouvement latéral — ID 100001

```
Wazuh Rule 100001 (level 12): lateral_movement detection Z3-USERS to Z3-USERS - MITRE
T1021. Rule 100002 (level 15): critical zone Z6-CRIT access attempt - MITRE T1190 -
apt_indicator alert.
```

Annexe C — Commandes de déploiement Keycloak (Docker Compose)

```
docker-compose.yml: services: postgres (postgres:15-alpine) + keycloak
(quay.io/keycloak/keycloak:24.0.3). KC_DB=postgres, KC_HOSTNAME=sso.xyz-internal.com,
KC_HTTP_ENABLED=false, KC_PROXY=edge. Port 8443. Networks: keycloak_net.
```

Annexe D — Glossaire technique complémentaire

Terme	Définition
Access Token	Jeton JWT (JSON Web Token) signé, émis par l'IdP, attestant l'identité et les droits de l'utilisateur. Durée de vie courte (5-15 min en ZTA).
BeyondCorp	Architecture Zero Trust développée et déployée par Google à partir de 2011, supprimant le VPN pour 100 000+ employés.
CASB	Cloud Access Security Broker — Intermédiaire de sécurité entre les utilisateurs et les services cloud, appliquant les politiques de sécurité.
Device Trust	Score de confiance attribué à un équipement selon sa conformité aux politiques : mises à jour, antivirus, chiffrement disque, certificat MDM.
East-West Traffic	Trafic réseau entre systèmes au sein d'un même datacenter ou segment réseau — vecteur principal des mouvements latéraux.
JWT	JSON Web Token — Standard RFC 7519 définissant un format compact et auto-

Terme	Définition
	porteur pour la transmission sécurisée d'informations sous forme de claims JSON signés.
Least Privilege	Principe du moindre privilège — chaque entité ne dispose que des droits strictement nécessaires à l'accomplissement de sa tâche.
Micro-segmentation	Division fine du réseau en zones isolées avec contrôle strict des flux inter-zones, limitant la propagation d'une compromission.
OIDC	OpenID Connect — Protocole d'authentification basé sur OAuth 2.0, permettant à un client de vérifier l'identité d'un utilisateur auprès d'un IdP.
Policy Engine	Composant central ZTA qui évalue les demandes d'accès en appliquant les politiques de sécurité définies et les données contextuelles.
SAML 2.0	Security Assertion Markup Language — Standard XML pour l'échange de données d'authentification et d'autorisation entre un IdP et un SP.
SDP	Software-Defined Perimeter — Architecture de sécurité réseau créant un périmètre virtuel défini par logiciel autour des ressources à protéger.
Zero Standing Privileges	Principe selon lequel aucun compte ne dispose de droits permanents — les privilèges sont accordés à la demande, pour la durée minimale nécessaire.

